

CISSP Manager-Mindset Guide

DOMAIN 7 | SECURITY OPERATIONS

Investigations • Monitoring • Incidents • Recovery • Continuity • Safety

PURPOSE A decision-oriented guide to operating controls, detecting and responding to events, preserving evidence, restoring services, and protecting people and the business.

Aligned to the ISC2 CISSP Certification Exam Outline effective April 15, 2024
Domain weight: 13%

How to Use This Guide

Domain 7 questions often test sequence under pressure. Determine whether there is imminent danger, whether the event is an incident, who has authority, what the response plan requires, whether evidence may be needed, and which business services must remain available before choosing a technical action.

DEFAULT DECISION LENS Life safety first. Follow the authorized plan. Stabilize and contain risk. Preserve evidence when circumstances permit. Communicate through defined channels. Recover to a trusted state. Conduct lessons learned and verify corrective action.

The Domain 7 Manager Mindset

- People and life safety take precedence over evidence, equipment, data, and service restoration.
- Preparation determines response quality: plans, roles, contacts, tooling, logging, backups, exercises, and authority must exist before crisis.
- Do not improvise outside authority when an approved incident, change, investigation, or recovery process applies.
- Containment choices balance business continuity, safety, evidence, attacker visibility, and spread—not technical purity alone.
- Logs and evidence require integrity, time synchronization, access control, retention, and documented handling.
- Backups are useful only when protected and restorations meet business RPO and RTO requirements.
- Configuration, patch, vulnerability, and change processes are connected lifecycle controls.
- Recovery is not complete until business owners validate service, monitoring resumes, and root causes are addressed.

Domain 7 Roadmap

Objective	Focus	Primary decision question
7.1	Investigations	How is evidence collected and handled lawfully and reliably?
7.2	Logging and monitoring	What activity must be visible, trustworthy, retained, and actionable?
7.3–7.5	Configuration, operations, resource protection	How are approved states, duties, privilege, SLAs, media, and data protected?
7.6	Incident management	How is an event detected, contained, communicated, recovered, and learned from?
7.7–7.9	Preventive controls, vulnerability, change	How are operational defenses maintained without uncontrolled disruption?
7.10–7.13	Recovery, DR, and BC	How are business requirements translated into tested recovery capability?
7.14–7.15	Physical security and personnel safety	How are people, facilities, travel, emergency, and duress risks controlled?

7.1 Investigations

Investigation Authority and Preparation

Easy definition: Investigations require a defined purpose, authority, scope, trained personnel, procedures, legal and HR coordination, evidence handling, and communication.

When it matters: Incidents, employee misconduct, fraud, litigation, regulatory inquiries, and suspected crime.

THINK LIKE A MANAGER Identify the investigation type and controlling authority before intrusive action; protect life first and coordinate with counsel, HR, compliance, or law enforcement as appropriate.

EXAM TRAPS

- Treating every security alert as a criminal investigation.
- Monitoring or searching without policy, notice, consent, or authority.
- Contacting law enforcement reflexively without organizational escalation unless safety or law requires it.
- Allowing curiosity to expand scope.

QUICK DISTINCTION Incident response restores and protects operations; an investigation establishes facts and accountability. They may overlap but have different objectives.

Evidence Collection and Order of Volatility

Easy definition: Evidence collection preserves relevant data in a repeatable manner; order of volatility prioritizes information that will disappear fastest, such as memory and live network state, before stable storage.

When it matters: Digital forensics, malware, compromised systems, cloud, mobile, and network investigations.

THINK LIKE A MANAGER Use trained personnel and approved methods, document the system state, minimize alteration, collect volatile evidence when justified, and image stable media before detailed analysis.

EXAM TRAPS

- Powering off immediately when volatile evidence is important and no safety need requires it.
- Collecting evidence at the expense of active life safety.
- Analyzing the original media when a verified forensic image can be used.
- Applying a memorized volatility order without considering cloud, encryption, remote access, or business impact.

QUICK DISTINCTION More volatile evidence disappears sooner; collection priority still depends on safety, authority, value, and feasibility.

Chain of Custody and Evidence Integrity

Easy definition: Chain of custody documents who collected, possessed, transferred, stored, and accessed evidence; integrity controls demonstrate that evidence remained unchanged.

When it matters: Litigation, disciplinary action, regulatory response, law enforcement, and internal investigations.

THINK LIKE A MANAGER Use unique identifiers, tamper-evident storage, hashes, restricted access, documented transfers, and repeatable tools so another party can defend the evidence history.

EXAM TRAPS

- Assuming a hash alone is chain of custody.
- Failing to record every transfer and access.
- Allowing evidence storage administrators unrestricted undocumented access.
- Using unvalidated tools without documenting limitations.
- Mixing originals and working copies.

QUICK DISTINCTION Hash supports integrity; chain of custody supports possession history; both contribute to authenticity and admissibility.

Forensic Images, Artifacts, and Analysis

Easy definition: A forensic image is a bit-level copy made and verified for analysis; artifacts are relevant traces from computers, networks, cloud, mobile devices, memory, applications, and accounts.

When it matters: Disk examination, timeline creation, malware analysis, attribution support, and incident scoping.

THINK LIKE A MANAGER Collect only relevant authorized data, preserve originals, validate copies, document tools and actions, protect privacy, and correlate artifacts before concluding.

EXAM TRAPS

- Calling an ordinary file copy a complete forensic image.
- Assuming deleted data is always recoverable.
- Overstating attribution from one IP address or artifact.
- Ignoring cloud-provider logs and mobile or network context.
- Retaining unrelated personal data indefinitely.

QUICK DISTINCTION Acquisition preserves data; examination extracts artifacts; analysis interprets and correlates; reporting communicates supported conclusions.

Reporting and Documentation

Easy definition: Investigation records capture authorization, scope, timeline, people, systems, evidence, methods, findings, uncertainty, decisions, and disposition.

When it matters: Incident reports, legal actions, audit response, lessons learned, and executive communication.

THINK LIKE A MANAGER Write contemporaneously, separate fact from inference, protect sensitive details, maintain reproducibility, and tailor reports without altering the evidence-backed conclusion.

EXAM TRAPS

- Writing notes only after the event.
- Mixing assumptions with observed facts.
- Using imprecise timestamps without time-zone context.
- Publishing exploit or personal details too broadly.
- Claiming certainty beyond the evidence.

QUICK DISTINCTION Facts are directly supported; inferences are reasoned conclusions; opinions must be clearly identified and within expertise.

7.2 Logging and Monitoring

Logging Strategy and Log Management

Easy definition: Logging defines which events are recorded; log management collects, normalizes, protects, retains, searches, and disposes of records across their lifecycle.

When it matters: Detection, troubleshooting, accountability, compliance, forensics, and performance.

THINK LIKE A MANAGER Begin with risks and use cases, ensure critical sources and fields are complete, synchronize time, protect integrity and privacy, and retain data only as justified.

EXAM TRAPS

- Collecting every possible event without use or capacity planning.
- Assuming the SIEM receives all source events correctly.
- Failing to log privileged, control-plane, cloud, and application actions.
- Allowing subjects to erase their own records.
- Keeping logs forever without legal and privacy review.

QUICK DISTINCTION Logging creates events; log management governs them; monitoring evaluates them; alerting signals conditions requiring action.

SIEM and Security Analytics

Easy definition: A SIEM centralizes security events, correlates data, applies detection logic, supports investigation, and enables reporting; analytics add context and behavior-based evaluation.

When it matters: SOC operations, compliance, threat detection, incidents, and hunting.

THINK LIKE A MANAGER Prioritize high-value use cases and data quality, tune detections, assign owners and playbooks, measure outcomes, and continuously validate source coverage.

EXAM TRAPS

- Treating SIEM installation as a monitoring program.
- Measuring success by events per second or alert count alone.
- Using default rules without environment context.
- Ignoring stale assets, identity context, time drift, parsing, and dropped logs.
- Allowing alert fatigue to become accepted normality.

QUICK DISTINCTION Correlation connects related events; enrichment adds context; triage determines priority and action.

IDS, IPS, and NDR

Easy definition: IDS detects suspicious activity; IPS can block it inline; NDR analyzes network behavior and telemetry for threats and anomalies.

When it matters: Perimeters, east-west traffic, OT monitoring, cloud, encrypted traffic metadata, and incident detection.

THINK LIKE A MANAGER Choose placement and enforcement from consequence and confidence; tune, monitor health, protect signatures and models, and design safe failure behavior.

EXAM TRAPS

- Deploying IPS inline in fragile OT without impact analysis.
- Assuming IDS prevents attacks.
- Treating signatures as complete coverage.
- Ignoring encrypted traffic, asymmetric routing, bypass, and sensor loss.
- Blocking on low-confidence anomaly alone.

QUICK DISTINCTION IDS is primarily detective; IPS adds preventive blocking; NDR emphasizes behavioral network visibility and investigation.

Egress Monitoring

Easy definition: Egress monitoring observes and controls outbound traffic to detect exfiltration, malware command channels, unauthorized services, and policy violations.

When it matters: Internet boundaries, cloud, DNS, email, proxies, remote access, and data loss prevention.

THINK LIKE A MANAGER Define legitimate destinations and data flows, filter outbound paths, monitor DNS and encrypted metadata, and coordinate DLP, endpoint, identity, and network evidence.

EXAM TRAPS

- Focusing only on inbound attacks.
- Allowing unrestricted outbound traffic because users initiated it.
- Blocking unusual traffic without business validation.
- Ignoring cloud-to-cloud and sanctioned SaaS exfiltration.
- Assuming encryption makes egress unobservable.

QUICK DISTINCTION Ingress protects what enters; egress governs what leaves; exfiltration may use legitimate protocols and authorized services.

Threat Intelligence and Threat Hunting

Easy definition: Threat intelligence provides analyzed information about adversaries, capabilities, indicators, and context; threat hunting proactively searches for evidence of compromise based on hypotheses.

When it matters: Detection engineering, prioritization, incidents, vulnerability management, and strategic risk.

THINK LIKE A MANAGER Select intelligence relevant to the organization, evaluate source confidence and timeliness, convert it into decisions, and hunt with hypotheses and measurable outcomes.

EXAM TRAPS

- Calling a raw indicator feed finished intelligence.
- Blocking every indicator without confidence or context.
- Treating absence of hunt findings as proof of no compromise.
- Hunting without adequate telemetry or defined hypothesis.
- Ignoring strategic and operational intelligence in favor of IP lists.

QUICK DISTINCTION Threat data are raw facts; intelligence is analyzed for a decision; hunting searches proactively for adversary behavior.

UEBA and Continuous Tuning

Easy definition: UEBA models user and entity behavior to identify anomalies; tuning adjusts detections, thresholds, data, and processes as environments and threats change.

When it matters: Insider risk, compromised accounts, cloud, privileged access, and alert reduction.

THINK LIKE A MANAGER Use behavior as one risk signal, validate models and bias, protect privacy, explain escalation, and combine anomalies with business and identity context.

EXAM TRAPS

- Treating anomaly as proof of malicious intent.
- Punishing unusual behavior without investigation.
- Ignoring role, location, leave, maintenance, and business-cycle changes.
- Using opaque risk scores without governance.
- Tuning by simply suppressing difficult alerts.

QUICK DISTINCTION Anomaly means deviation from baseline; risk requires context, potential consequence, and supporting evidence.

7.3–7.5 Configuration, Operations, and Resource Protection

Configuration Management and Baselines

Easy definition: Configuration management identifies and controls approved system attributes throughout the lifecycle; a baseline is the formally approved reference state.

When it matters: Provisioning, hardening, patching, automation, audits, drift detection, and recovery.

THINK LIKE A MANAGER Define secure baselines from requirements, record approved state, control changes, monitor drift, and preserve tested configuration recovery.

EXAM TRAPS

- Calling any current configuration a baseline.
- Hardening without documenting business exceptions.
- Using automation to propagate an untested error widely.
- Detecting drift without assigning correction ownership.
- Ignoring cloud, network, firmware, and application configuration.

QUICK DISTINCTION Baseline is the approved reference; configuration item is a controlled component; drift is unauthorized or unintended deviation.

Provisioning, Automation, and Infrastructure as Code

Easy definition: Automated provisioning and infrastructure as code create repeatable environments from versioned definitions and policy.

When it matters: Cloud, containers, servers, networks, endpoints, CI/CD, and rapid recovery.

THINK LIKE A MANAGER Secure templates and pipelines, review changes, scan dependencies and secrets, test before promotion, separate duties, and monitor deployed state against code.

EXAM TRAPS

- Assuming repeatable means secure.
- Embedding secrets in templates or repositories.
- Letting one privileged pipeline change every environment without safeguards.
- Ignoring manual changes outside code.
- Deploying from untrusted modules or images.

QUICK DISTINCTION IaC defines desired infrastructure state; configuration management ensures actual state remains authorized and controlled.

Separation of Duties, Job Rotation, and Mandatory Vacation

Easy definition: Operational controls divide critical tasks and periodically expose work to independent performance or review to reduce fraud, error, and concealment.

When it matters: Privileged administration, payments, backups, key management, code deployment, and monitoring.

THINK LIKE A MANAGER Prevent one person from authorizing, performing, and hiding sensitive activity; maintain coverage and review emergency exceptions.

EXAM TRAPS

- Using two accounts owned by one person as separation.
- Treating job rotation as permission to accumulate access.
- Calling mandatory vacation an availability benefit only.
- Allowing administrators to modify their own audit trails.
- Letting small-team constraints become undocumented permanent risk.

QUICK DISTINCTION Job rotation changes who performs duties; mandatory vacation removes a person temporarily so concealed activity may surface.

Privileged Accounts and Service-Level Agreements

Easy definition: Privileged accounts can alter critical systems and controls; SLAs define measurable service commitments, responsibilities, remedies, and reporting.

When it matters: Administration, managed services, cloud, network support, incident response, and recovery.

THINK LIKE A MANAGER Use separate time-bound privileged identities with monitoring; make service commitments trace to business needs and verify performance rather than relying on contract language.

EXAM TRAPS

- Using shared administrator accounts.
- Treating an SLA credit as continuity or risk treatment.
- Setting technical availability targets without business requirements.
- Ignoring exclusions, measurement methods, dependencies, and incident obligations.
- Letting vendors administer without monitored named identities.

QUICK DISTINCTION SLA defines service performance; OLA coordinates internal teams; contract allocates broader duties and remedies.

Media Management and Protection

Easy definition: Media management inventories, labels, stores, transports, uses, retains, sanitizes, and disposes of physical and logical media according to classification.

When it matters: Backups, removable media, portable devices, tapes, paper, cloud exports, and evidence.

THINK LIKE A MANAGER Minimize removable media, require authorization and encryption, maintain custody, protect storage, scan transfers, and verify disposition.

EXAM TRAPS

- Protecting data at rest but not during transport.
- Assuming encryption removes inventory and custody needs.
- Reusing media after simple deletion.
- Ignoring printer storage, mobile devices, failed drives, and cloud snapshots.
- Destroying media subject to legal hold.

QUICK DISTINCTION Media handling follows the data classification; sanitization method follows sensitivity, media technology, and reuse or disposal destination.

Data at Rest and in Transit Operations

Easy definition: Operational data protection applies access control, encryption, integrity, key management, monitoring, backup, retention, and secure transfer to stored and moving data.

When it matters: Databases, file systems, endpoints, backups, email, APIs, remote access, and vendor exchange.

THINK LIKE A MANAGER Map every copy and path, protect keys separately, verify recipients and endpoints, monitor use, and ensure controls remain effective during recovery and maintenance.

EXAM TRAPS

- Assuming disk encryption protects data from a logged-in compromised account.
- Encrypting transit while exposing endpoints or metadata.
- Storing keys with encrypted backups.
- Using ad hoc consumer transfer services.
- Failing to protect temporary files and exports.

QUICK DISTINCTION At-rest encryption protects stored media; transport encryption protects a communication path; application-level protection can persist across intermediaries.

7.6 Incident Management

Incident Preparation and Detection

Easy definition: Preparation establishes policy, roles, authority, playbooks, contacts, tools, telemetry, evidence procedures, communications, exercises, backups, and recovery; detection identifies possible events requiring triage.

When it matters: Every incident type, including ransomware, data breach, insider activity, cloud compromise, and OT disruption.

THINK LIKE A MANAGER Invest before crisis: define decision rights, severity criteria, legal and regulatory triggers, safe containment, and business restoration priorities.

EXAM TRAPS

- Writing a plan without exercising it.
- Treating every alert as an incident.
- Ignoring third-party and executive contacts.
- Waiting for an incident to establish evidence and communication procedures.
- Failing to define who may isolate critical systems.

QUICK DISTINCTION Event is an observable occurrence; alert is a signal; incident is an event that violates or threatens policy, operations, or security and requires response.

Triage, Analysis, and Classification

Easy definition: Triage validates the alert, estimates severity, scope, confidence, affected assets and business impact, and assigns response priority and ownership.

When it matters: SOC operations, escalation, incident declaration, and resource allocation.

THINK LIKE A MANAGER Use predefined criteria and business context, escalate uncertainty appropriately, preserve evidence, and avoid premature attribution or closure.

EXAM TRAPS

- Prioritizing solely by tool severity.
- Closing an alert because no known signature fired.
- Declaring a breach before facts support it.
- Investigating low-value systems while critical spread continues.
- Ignoring safety and operational consequence.

QUICK DISTINCTION Triage decides what deserves attention now; analysis develops scope, cause, timeline, and impact as evidence grows.

Containment and Mitigation

Easy definition: Containment limits spread and damage; mitigation reduces immediate risk while preserving necessary operations and evidence.

When it matters: Malware, account compromise, data exfiltration, denial of service, insider threats, cloud, and OT.

THINK LIKE A MANAGER Choose short- and long-term containment with business owners and responders,

balancing safety, continuity, evidence, attacker awareness, and eradication needs.

EXAM TRAPS

- Automatically powering off every compromised system.
- Keeping a system online solely to observe an attacker without authority.
- Blocking one indicator while the attack path remains.
- Applying disruptive containment in critical operations without coordination.
- Confusing containment with eradication.

QUICK DISTINCTION Containment limits the incident; eradication removes cause and persistence; recovery restores trusted operation.

Reporting, Communications, and Notification

Easy definition: Incident communication provides accurate, timely, need-to-know information to responders, leadership, employees, customers, regulators, insurers, law enforcement, and partners through authorized channels.

When it matters: Material incidents, privacy breaches, service outages, public communications, and regulatory deadlines.

THINK LIKE A MANAGER Use a communication lead and approved plan, preserve privilege where applicable, meet notification obligations, avoid speculation, and maintain consistent facts.

EXAM TRAPS

- Having technical responders speak publicly without authorization.
- Delaying required notification until every detail is known.
- Over-notifying without legal and business review.
- Using compromised communication channels.
- Allowing different teams to report conflicting facts.

QUICK DISTINCTION Internal escalation activates governance; external notification fulfills legal, contractual, regulatory, or stakeholder duties.

Recovery, Remediation, and Lessons Learned

Easy definition: Recovery restores services to a trusted state; remediation corrects weaknesses and root causes; lessons learned improves people, process, technology, and plans after stabilization.

When it matters: Every material incident and exercise.

THINK LIKE A MANAGER Restore from known-good sources, validate with business owners, monitor for recurrence, document residual risk, and assign corrective actions with dates and verification.

EXAM TRAPS

- Restoring quickly without removing persistence or compromised credentials.
- Declaring recovery when systems boot but business transactions fail.
- Holding lessons learned as a blame session.
- Closing the incident before evidence, reporting, and corrective actions are owned.
- Failing to retest remediated controls.

QUICK DISTINCTION Recovery returns capability; remediation reduces recurrence; lessons learned turns experience into verified improvement.

Incident Response Sequence

Phase	Manager question	Typical actions
Preparation	Are roles, authority, tools, evidence, communications, and recovery ready?	Plans, exercises, logging, backups, contacts
Detection/analysis	Is this an incident, how severe, and what is affected?	Validate, classify, scope, preserve evidence
Containment	How do we limit harm safely?	Isolate identities, systems, paths, or data as appropriate
Eradication	What cause and persistence must be removed?	Remove malware, close path, reset trust, patch root cause
Recovery	How do we restore trusted business service?	Restore, validate, monitor, communicate
Post-incident	What must change and how will closure be proven?	Lessons, actions, owners, retest, metrics

7.7 Operate Detection and Preventive Measures

Firewalls, WAFs, IDS, and IPS

Easy definition: Network firewalls control flows, WAFs inspect web application traffic, IDS detects suspicious activity, and IPS can block traffic inline.

When it matters: Perimeters, segmentation, applications, cloud, OT, and egress control.

THINK LIKE A MANAGER Place controls at meaningful trust boundaries, default-deny where practical, tune and monitor them, control rule changes, and design safe failure and redundancy.

EXAM TRAPS

- Using a WAF instead of fixing application flaws.
- Assuming IDS blocks attacks.
- Allowing broad temporary rules permanently.
- Deploying IPS inline without consequence analysis.
- Ignoring encrypted traffic and bypass paths.

QUICK DISTINCTION Firewall enforces network policy; WAF focuses on web-layer patterns; IDS detects; IPS detects and can prevent.

Allowlisting, Blocklisting, and Application Control

Easy definition: Allowlisting permits only approved items; blocklisting denies known-bad items; application control governs which software or code may run.

When it matters: Endpoints, servers, email, web, scripts, removable media, and high-control environments.

THINK LIKE A MANAGER Use allowlisting for stable high-value systems where operational governance supports it; maintain emergency, update, and exception processes.

EXAM TRAPS

- Calling allowlisting complete protection against trusted-tool abuse.
- Relying on blocklists for unknown threats.
- Enforcing application control before inventory and compatibility testing.
- Failing to govern scripts, interpreters, libraries, and signed malicious code.

QUICK DISTINCTION Allowlisting starts denied and permits known-approved; blocklisting starts allowed and denies known-bad.

Sandboxing, Honeypots, and Deception

Easy definition: Sandboxing isolates untrusted code or content for analysis; honeypots and honeynets are decoy resources designed to detect, study, or divert attackers.

When it matters: Malware analysis, email, browsers, threat research, early detection, and deception.

THINK LIKE A MANAGER Isolate deception systems from production, define legal and monitoring objectives, prevent them from becoming attack platforms, and treat activity as evidence—not automatic attribution.

EXAM TRAPS

- Assuming sandbox escape is impossible.
- Placing real sensitive data in a honeypot.
- Using deception without monitoring or response.
- Confusing a honeypot with an ordinary vulnerable production system.
- Taking offensive retaliatory action against observed attackers.

QUICK DISTINCTION Sandbox contains code execution; honeypot attracts interaction; honeynet is a network of decoys.

Anti-Malware, EDR, AI, and Machine Learning Tools

Easy definition: Anti-malware detects known and suspicious malicious code; EDR records endpoint activity and supports detection and response; AI/ML tools identify patterns and assist prioritization or automation.

When it matters: Endpoints, servers, cloud workloads, SOC, ransomware, and threat hunting.

THINK LIKE A MANAGER Use layered endpoint controls with managed policy, telemetry, response authority, tuning, privacy, and recovery; validate automated actions and model limitations.

EXAM TRAPS

- Treating an installed agent as proof of coverage or health.
- Assuming AI conclusions are accurate and unbiased.
- Allowing automated isolation of critical systems without safety controls.
- Ignoring unsupported endpoints and offline devices.
- Using EDR instead of patching and least privilege.

QUICK DISTINCTION Anti-malware focuses on malicious content; EDR adds behavioral telemetry and response; neither replaces secure design, identity, or recovery.

7.8–7.9 Vulnerability, Patch, and Change Management

Vulnerability Management Lifecycle

Easy definition: Vulnerability management discovers assets and weaknesses, validates and prioritizes risk, assigns treatment, tracks exceptions, verifies remediation, and reports trends continuously.

When it matters: Endpoints, servers, network, cloud, applications, containers, OT, and third parties.

THINK LIKE A MANAGER Prioritize by business criticality, exposure, exploitability, threat activity, compensating controls, and consequence—not severity score alone.

EXAM TRAPS

- Scanning before inventory and authorization.
- Treating CVSS as business risk.
- Counting duplicate findings as separate priorities.
- Closing after patch deployment without rescanning or validation.
- Ignoring unsupported, misconfigured, identity, and third-party risk.

QUICK DISTINCTION Vulnerability assessment identifies weaknesses; vulnerability management governs their treatment through verified closure.

Patch Management

Easy definition: Patch management identifies, acquires, validates, prioritizes, tests, deploys, verifies, rolls back, and documents updates.

When it matters: Operating systems, applications, firmware, network devices, cloud images, and OT.

THINK LIKE A MANAGER Use risk-based urgency and staged testing, protect supply-chain integrity, plan rollback and recovery, coordinate operations, and verify actual installation and service health.

EXAM TRAPS

- Deploying every patch immediately to fragile production.
- Delaying critical patches solely for a routine cycle without risk treatment.
- Assuming the vendor update is authentic without validation.
- Patching one instance while templates remain vulnerable.
- Calling deployment success proof that the vulnerability is gone.

QUICK DISTINCTION Patch management applies fixes; vulnerability management includes patches plus configuration, mitigation, acceptance, replacement, and verification.

Change Management

Easy definition: Change management evaluates, approves, tests, schedules, communicates, implements, validates, documents, and reviews modifications to reduce uncontrolled risk.

When it matters: Patches, configuration, network rules, applications, cloud, facilities, and emergency response.

THINK LIKE A MANAGER Use proportional governance, separation of duties, impact and rollback plans, business approval, and post-implementation validation; process emergency changes retrospectively.

EXAM TRAPS

- Treating change control as a reason never to patch.
- Allowing the implementer to approve high-risk changes alone.
- Skipping rollback and communication.
- Leaving emergency changes undocumented.
- Confusing standard preapproved changes with unauthorized changes.

QUICK DISTINCTION Change management governs whether and when a change proceeds; configuration management records and maintains the approved state.

Emergency, Standard, and Normal Changes

Easy definition: Standard changes are low-risk, repeatable, and preauthorized; normal changes follow regular assessment and approval; emergency changes use expedited authority to address urgent risk or outage.

When it matters: Operational governance, incidents, patching, outages, and service requests.

THINK LIKE A MANAGER Define categories and authority in advance, limit emergency use, preserve evidence, validate outcomes, and perform retrospective review.

EXAM TRAPS

- Calling an avoidable late request an emergency.
- Skipping all testing and rollback because a change is urgent.
- Using standard-change status for materially different implementations.
- Failing to review emergency changes after stabilization.

QUICK DISTINCTION Emergency means expedited control—not no control. Standard means preapproved under defined repeatable conditions—not unrestricted.

7.10 Recovery Strategies

Backup Types and Storage Strategies

Easy definition: Full backups copy all selected data; incremental backups copy changes since the most recent backup; differential backups copy changes since the last full backup. Copies may be onsite, offsite, offline, immutable, or cloud-based.

When it matters: RPO, RTO, ransomware, legal retention, bandwidth, restore complexity, and resilience.

THINK LIKE A MANAGER Select backup architecture from business recovery objectives, isolate administrative control, maintain multiple failure domains, verify integrity, and test restoration.

EXAM TRAPS

- Choosing backup type only by backup speed.
- Treating snapshots or replication as complete backups.
- Keeping every copy under one compromised identity plane.
- Ignoring bandwidth and egress time during cloud recovery.
- Assuming offsite means offline or immutable.

QUICK DISTINCTION Incremental restore needs the last full plus each incremental; differential restore needs the last full plus latest differential.

Recovery Sites and Capacity Agreements

Easy definition: Cold sites provide facility and basic infrastructure; warm sites provide partial systems and connectivity; hot sites are substantially ready; mobile or reciprocal arrangements offer alternatives with different assurance.

When it matters: Disaster recovery, geographic resilience, cost, RTO, and critical services.

THINK LIKE A MANAGER Select from BIA requirements, verify capacity and data currency, separate hazards and providers, contract for priority, and test realistic activation.

EXAM TRAPS

- Choosing a hot site for every system regardless of cost and need.
- Assuming a reciprocal agreement guarantees compatible capacity during a regional event.
- Locating recovery and primary sites in one hazard zone.
- Ignoring staffing, data, licenses, network, identity, and vendor dependencies.
- Relying on SLA remedies instead of recovery capability.

QUICK DISTINCTION Hot is fastest and most expensive; warm is partially ready; cold requires the most setup and time.

Resilience, High Availability, Fault Tolerance, and QoS

Easy definition: Resilience withstands and recovers from disruption; high availability minimizes downtime; fault tolerance continues through component failure; QoS prioritizes traffic under constrained conditions.

When it matters: Architecture, clusters, networks, storage, applications, and critical operations.

THINK LIKE A MANAGER Design to business service objectives, remove common-mode failures, monitor end-

to-end health, and test degraded and failover states under load.

EXAM TRAPS

- Calling redundancy fault tolerance without automatic continued operation.
- Duplicating components on shared power, network, identity, or storage.
- Assuming QoS adds capacity.
- Testing device failover but not business transactions.
- Ignoring data consistency and split-brain risk.

QUICK DISTINCTION Fault tolerance seeks uninterrupted operation; HA minimizes interruption; resilience includes adaptation and recovery beyond redundancy.

Multiple Processing Sites and Geographic Resilience

Easy definition: Multiple sites distribute processing and recovery capability across failure domains using active-active, active-passive, or other patterns.

When it matters: Regional disasters, global services, cloud regions, data centers, and critical infrastructure.

THINK LIKE A MANAGER Choose data consistency, traffic, capacity, failover, and geographic separation from business requirements; validate independence and regulatory location constraints.

EXAM TRAPS

- Assuming two availability zones protect against regional failure.
- Running active-active without conflict and consistency design.
- Failing to test DNS, routing, certificates, identity, and data promotion.
- Ignoring correlated provider and software failures.

QUICK DISTINCTION Active-active serves load from multiple sites; active-passive keeps standby capacity for failover. Both require tested orchestration and data strategy.

7.11 Implement Disaster Recovery Processes

DR Activation, Assessment, and Response

Easy definition: DR begins when authorized leadership declares or activates recovery based on disruption, impact, safety, and expected duration; teams assess damage and execute prioritized procedures.

When it matters: Facility loss, cyberattack, utility failure, regional event, and major technology outage.

THINK LIKE A MANAGER Use predefined authority and criteria, protect people, establish command and communications, assess business impact, and recover according to BIA priorities rather than technical convenience.

EXAM TRAPS

- Allowing a technician to declare enterprise disaster without authority.
- Recovering easiest systems first.
- Entering an unsafe facility to assess equipment.
- Failing to distinguish incident containment from disaster recovery activation.
- Ignoring regulatory and customer communications.

QUICK DISTINCTION Incident response addresses harmful events; DR restores technology after major disruption; BC sustains critical business functions throughout.

Personnel and Communications

Easy definition: Recovery requires current roles, alternates, contact methods, call trees, decision authority, travel and remote-work plans, vendor coordination, and redundant communications.

When it matters: Declared disasters, regional outages, cyber incidents, and exercises.

THINK LIKE A MANAGER Plan for unavailable leaders, damaged channels, family and safety concerns, and conflicting information; use an authoritative communication process.

EXAM TRAPS

- Maintaining one contact list only on affected systems.
- Assuming staff can reach the recovery site.
- Relying on one telecommunications provider.
- Ignoring employee welfare and family obligations.
- Publishing unverified status.

QUICK DISTINCTION Call tree distributes notification; crisis communication coordinates consistent facts and decisions across stakeholders.

Restoration and Business Validation

Easy definition: Restoration rebuilds systems, data, connectivity, identity, and controls in dependency order; business validation confirms the recovered service works correctly for intended operations.

When it matters: Backups, recovery sites, cloud rebuilds, ransomware, and infrastructure replacement.

THINK LIKE A MANAGER Restore to a trusted state, verify integrity and security, reconcile data, obtain business-owner acceptance, monitor closely, and plan return to normal operations.

EXAM TRAPS

- Restoring malware or compromised credentials from backup.
- Declaring success when servers start.
- Ignoring interfaces, upstream and downstream systems, and manual transactions.
- Returning to the primary site without controlled failback.
- Disabling monitoring to speed recovery.

QUICK DISTINCTION Technical restoration makes components available; business validation proves the process and outcomes are usable.

Training, Awareness, and Lessons Learned for DR

Easy definition: Recovery capability depends on trained people, exercised plans, documented results, assigned corrective actions, and updated dependencies.

When it matters: DR programs, new personnel, system changes, suppliers, and post-disaster improvement.

THINK LIKE A MANAGER Train roles before exercises, evaluate decisions and outcomes, correct root causes, update plans and inventories, and verify actions at the next exercise.

EXAM TRAPS

- Using plan distribution as training.
- Treating exercise completion as proof of success.
- Punishing participants for exposing weaknesses.
- Failing to budget corrective action.
- Leaving plans unchanged after architecture or vendor changes.

QUICK DISTINCTION Training builds role capability; exercises validate coordinated performance; lessons learned drive verified improvement.

7.12 Test Disaster Recovery Plans

Read-Through and Tabletop Exercises

Easy definition: A read-through reviews the plan for accuracy and understanding; a tabletop discusses a scenario and decisions without operating production recovery systems.

When it matters: Early validation, leadership coordination, communications, role training, and low-disruption testing.

THINK LIKE A MANAGER Use realistic scenarios and injects, require decisions, capture assumptions and gaps, and assign corrective actions; do not overclaim technical validation.

EXAM TRAPS

- Calling document review a full DR test.
- Letting participants skip hard decisions because it is hypothetical.
- Using only the expected scenario.
- Failing to include business, legal, communications, vendors, and executives.

QUICK DISTINCTION Read-through checks the plan; tabletop rehearses decisions and coordination; neither proves systems can be restored.

Walkthrough and Simulation

Easy definition: A walkthrough steps through procedures and locations in more operational detail; a simulation models disaster conditions and response without fully interrupting production.

When it matters: Team readiness, facilities, communications, alternate processes, and coordinated recovery.

THINK LIKE A MANAGER Increase realism and participation while protecting operations; define objectives, observers, safety, and success measures.

EXAM TRAPS

- Confusing walkthrough with actual recovery.
- Simulating only technical teams.
- Failing to test alternate communications and manual workarounds.
- Using scripted success with no unexpected injects.

QUICK DISTINCTION Walkthrough follows procedures; simulation imitates event conditions and actions; technical activation may still be limited.

Parallel and Full-Interruption Tests

Easy definition: Parallel testing activates recovery capability while production continues; full interruption stops or redirects production to validate actual recovery and carries the greatest operational risk.

When it matters: Mature DR programs, critical systems, recovery sites, and regulatory requirements.

THINK LIKE A MANAGER Use progressively stronger testing based on risk and maturity, obtain executive approval, define rollback and safety, communicate status, and protect customers and operations.

EXAM TRAPS

- Choosing full interruption first because it provides strongest evidence.
- Calling a backup restore parallel processing without service validation.
- Running production and recovery against the same writable data without control.
- Failing to notify stakeholders that exercise messages are tests.
- Testing failover without failback.

QUICK DISTINCTION Parallel validates alternate processing alongside production; full interruption proves actual cutover but creates the most business risk.

DR Test Progression

Type	Operational realism	Primary limitation
Read-through	Low	Validates document understanding, not execution
Tabletop	Low to moderate	Validates decisions and coordination, not technical recovery
Walkthrough	Moderate	Steps through procedures with limited live operation
Simulation	Moderate to high	Models response but may not use full production dependencies
Parallel	High	Recovery runs while production remains available
Full interruption	Highest	Strong evidence but greatest operational and customer risk

7.13 Business Continuity Planning and Exercises

Business Continuity Operations

Easy definition: BC sustains prioritized business functions through disruption using alternate people, facilities, technology, suppliers, communications, and manual workarounds.

When it matters: Cyber incidents, facility loss, workforce disruption, utility failure, supply chain, and regional disasters.

THINK LIKE A MANAGER Use the BIA to prioritize functions and dependencies, establish continuity strategies, integrate crisis and DR plans, and exercise end-to-end business outcomes.

EXAM TRAPS

- Treating BC as an IT recovery plan.
- Ignoring external dependencies and single-skilled personnel.
- Designing manual workarounds without data reconciliation.
- Failing to define maximum duration for degraded operations.
- Exercising technology without business process owners.

QUICK DISTINCTION BC keeps the business operating; DR restores technology; crisis management governs the broader event and decisions.

Plan Maintenance and Exercises

Easy definition: Continuity plans must be reviewed after organizational, technology, facility, supplier, legal, threat, and personnel changes and after exercises or incidents.

When it matters: Mergers, cloud migration, new sites, staffing changes, vendor changes, and emerging risks.

THINK LIKE A MANAGER Assign plan owners and review triggers, verify contact and dependency data, exercise varied scenarios, and track corrective actions to closure.

EXAM TRAPS

- Updating only on an annual calendar.
- Maintaining plans on unavailable systems.
- Using the same successful scenario repeatedly.
- Failing to involve executives, suppliers, and public communications.
- Treating stale contact details as minor.

QUICK DISTINCTION Scheduled review provides minimum cadence; event-driven review keeps plans aligned with material change.

7.14–7.15 Physical Security and Personnel Safety

Perimeter and Internal Physical Controls

Easy definition: Physical controls deter, prevent, detect, delay, and support response through barriers, lighting, guards, locks, badges, mantraps, sensors, surveillance, visitor procedures, and restricted zones.

When it matters: Sites, offices, data centers, wiring closets, evidence, media, loading docks, and critical infrastructure.

THINK LIKE A MANAGER Design layered zones from asset and threat analysis, enforce least privilege, protect alternate entries and utilities, monitor controls, and ensure response can arrive in time.

EXAM TRAPS

- Treating cameras as prevention rather than mostly deterrence/detection.
- Allowing tailgating through convenience doors.
- Using one access zone for all internal areas.
- Ignoring loading docks, roofs, shared walls, and utility access.
- Keeping access after transfer or termination.

QUICK DISTINCTION Perimeter controls establish outer protection; internal controls limit movement and protect higher-value zones after entry.

Travel and Remote Personnel Safety

Easy definition: Travel security addresses destination risk, devices, communications, tracking, medical needs, local law, kidnapping, surveillance, and emergency contact.

When it matters: Executives, field engineers, international travel, high-risk regions, and remote operations.

THINK LIKE A MANAGER Perform risk-based briefings, minimize data and privilege, provide safe communications and check-ins, define emergency assistance, and prioritize the person over device recovery.

EXAM TRAPS

- Giving every traveler the same generic guidance.
- Carrying unnecessary sensitive data or privileged credentials.
- Attempting to retrieve stolen equipment at personal risk.
- Ignoring local law and border-search authority.
- Tracking employees without privacy and consent governance.

QUICK DISTINCTION Travel security protects the person first; data-minimized loaner devices reduce consequence without shifting risk to the traveler.

Emergency Management, Evacuation, and Duress

Easy definition: Emergency management coordinates life safety, evacuation or shelter, accountability, emergency services, communications, and continuity; duress controls let people signal coercion or danger safely.

When it matters: Fire, violence, severe weather, medical events, hazardous materials, civil unrest, and workplace threats.

THINK LIKE A MANAGER Follow trained emergency authority, evacuate or shelter as directed, account for

people, support accessibility, communicate reliably, and resume operations only when safe.

EXAM TRAPS

- Preserving evidence or equipment before evacuating.
- Using elevators during fire when prohibited.
- Publishing sensitive duress procedures broadly.
- Failing to include visitors and people needing assistance.
- Re-entering without authority.

QUICK DISTINCTION Evacuation moves people from danger; shelter-in-place protects them where movement is more dangerous; the incident commander determines the appropriate action.

Security Awareness and Human-Factor Threats

Easy definition: Personnel safety and security awareness cover insider threats, social media exposure, phishing, MFA fatigue, workplace violence indicators, reporting, and emergency behavior.

When it matters: Daily operations, remote work, public exposure, authentication, and crisis readiness.

THINK LIKE A MANAGER Make reporting easy and nonpunitive, use resistant technology, protect privacy, train role-specific behavior, and route concerns through qualified HR, legal, safety, and security teams.

EXAM TRAPS

- Treating unusual behavior as proof of malicious insider activity.
- Blaming users for MFA fatigue without changing prompts and controls.
- Monitoring employees without authority and privacy review.
- Encouraging confrontation of suspicious people.
- Publishing employee travel or facility details on social media.

QUICK DISTINCTION Awareness helps people recognize and report; investigation and response must remain evidence-based, authorized, and respectful of rights.

Cross-Domain Exam Traps for Domain 7

What Takes Priority?

Situation	First priority	Attractive trap
Immediate danger to people	Life safety, emergency authority, evacuation/shelter	Preserve evidence or save equipment
Active incident without life danger	Follow plan, validate, contain proportionately	Power off everything immediately
Potential legal evidence	Preserve and document with trained handling	Analyze the original media
Critical OT disruption	Safety and process stability with operations	Apply standard enterprise containment blindly
Recovery decision	BIA priorities and trusted restoration	Recover easiest servers first
Unsupported vulnerable system	Risk assessment, compensating controls, exit plan	Patch unsafely or accept forever
DR test selection	Progressive evidence proportional to risk	Full interruption as first test

What Happens First?

- Immediate threat: protect people and contact emergency authority before protecting systems or evidence.
- Suspected incident: follow the response plan, validate and classify, establish authority, and preserve evidence.
- Containment: understand business, safety, spread, evidence, and recovery impact before disruptive isolation.
- Log program: define use cases, sources, required events, ownership, time, integrity, retention, and response.
- Vulnerability: validate risk and affected assets before selecting patch, mitigation, acceptance, or replacement.
- Recovery architecture: conduct BIA and set RPO/RTO before selecting backup types or recovery sites.
- DR activation: authorized leadership assesses impact and declares according to predefined criteria.
- Post-incident or exercise: stabilize first, then conduct lessons learned, assign actions, and verify closure.

ROOT-CAUSE TRAP Operational excellence is not the number of alerts, patches, backups, or plans. It is the ability to prevent, detect, respond, recover, protect people, and demonstrate that corrective actions reduced business risk.

Domain 7 Rapid Review

ONE-SENTENCE DOMAIN SUMMARY Operate security in a controlled and observable state; protect people first; respond through authorized plans; preserve trustworthy evidence; contain and eradicate threats; restore prioritized business services; and verify improvement through exercises and lessons learned.

High-Yield Distinctions

Concept A	Concept B	Fast distinction
Event	Incident	Observable occurrence vs. harmful/policy-violating event requiring response
Containment	Eradication	Limits spread/impact vs. removes cause and persistence
Recovery	Remediation	Restores service vs. corrects weakness/root cause
Chain of custody	Hash	Possession history vs. integrity evidence
IDS	IPS	Detects vs. detects and can block
Allowlist	Blocklist	Permit approved only vs. deny known-bad
Honeypot	Sandbox	Decoy attracting interaction vs. isolated execution environment
Configuration management	Change management	Maintains approved state vs. governs modifications
Vulnerability management	Patch management	Risk-treatment lifecycle vs. update lifecycle
Incremental	Differential	Since last backup vs. since last full
Hot site	Cold site	Substantially ready vs. facility/basic infrastructure
High availability	Fault tolerance	Minimizes downtime vs. continues through component failure
BC	DR	Sustains business functions vs. restores technology
Tabletop	Parallel test	Discusses decisions vs. runs recovery alongside production
Evacuation	Shelter-in-place	Move from danger vs. remain protected where moving is riskier

Final Manager-Mindset Checklist

- Is anyone in immediate danger, and who has emergency authority?
- Which approved incident, investigation, change, crisis, BC, or DR process applies?
- What business service, safety function, data, evidence, and legal obligation are at risk?
- Are logging, time, evidence integrity, custody, communications, and decision records trustworthy?
- Will containment reduce harm without creating unacceptable safety, continuity, or evidence loss?
- Are configuration, vulnerability, patch, and change activities tied to inventory and verified outcomes?
- Do backups, alternate sites, people, networks, identity, vendors, and data meet BIA-derived RPO/RTO?
- Has restoration returned a trusted service that business owners validated?
- Were required notifications made through authorized channels with supported facts?
- Did lessons learned produce owned, funded, time-bound corrective actions that were retested?

Source and Scope Note

Coverage is aligned to the ISC2 CISSP Certification Exam Outline effective April 15, 2024. This independent study aid uses original explanations and does not reproduce exam questions or official courseware. Official outline: <https://www.isc2.org/certifications/cissp/cissp-certification-exam-outline>